Apex Financial Partners: CIS Controls Gap Analysis Executive Summary

October 18, 2026 · Miles Brandon

Apex meets about 13% of the CIS Controls baseline for small firms, and the most urgent fixes can start this month at low cost.

Scope

This assessment measured Apex Financial Partners, a 30-person financial advisory and accounting firm, against all 56 safeguards in CIS Controls v8.1 Implementation Group 1 (IG1). IG1 is the essential cyber hygiene baseline CIS recommends for small firms with limited IT staff. Each safeguard was scored Implemented, Partial, or Not Implemented and linked to the risks in the Apex risk register.

Overall result

Apex scores about 13% coverage: 2 safeguards implemented, 11 partial, and 43 not implemented. This is common for a firm with no dedicated IT staff, but it means Apex is exposed to the everyday attacks that cause most small-firm breaches, such as phishing, stolen passwords, and ransomware.

Result	Safeguards
Implemented	2
Partial	11
Not Implemented	43
Total	**56**

Biggest gaps

Four gaps line up with the highest-rated risks in the register:

- **Phishing and staff training (R-04, Critical):** Apex has no security awareness program, and sensitive information is sent over email. All 8 training safeguards are unmet.
- **Backups (R-08, Critical):** Backups run automatically but have never been tested, and there is no offline copy. Ransomware could encrypt the files and the backups together.
- **Accounts and passwords (R-01, R-14):** Shared logins are in use, passwords are saved in browsers, and former staff accounts are never removed. Account Management scores 0%.
- **MFA (R-03, R-04, R-09, R-14):** The client portal, email, banking, and VPN rely on passwords alone.

90-day plan

The full roadmap covers all 27 high-priority gaps in three phases. The first 30 days focus on fixes that are fast and cheap:

1. **Days 0–30:** Turn on MFA for the client portal, email, banking, and VPN. Disable former staff accounts and key fobs. Add an offline backup and run a test restore. Patch the VPN gateway. Start phishing training. Name one person to lead incident response.
2. **Days 31–60:** Roll out a password manager and end shared logins, encrypt laptops and phones, set patch timelines, secure network device settings, and list every outside vendor.
3. **Days 61–90:** Map where client data lives and limit access by role, track whether software is still supported, and train staff on data handling and public Wi-Fi.

Decisions needed from leadership

- **Engage an outside IT provider.** Apex has no IT staff, and most technical fixes need one.
- **Approve a password manager and phishing training.** Both are low-cost and directly address the Critical phishing risk.
- **Assign owners.** Name an incident response lead and confirm the office manager owns account and vendor lists.

Fictional firm. All current states and scores are my own judgments for a hypothetical organization. No systems were tested or scanned. *Safeguards: CIS Critical Security Controls v8.1, Center for Internet Security, licensed CC BY-NC-ND 4.0.*